

Requiring Signed GitHub Commits

Final Technical Report

Maggie Ring

maggie.ring@colostate.edu

Colorado State University - Computer Science

Table of contents

1	Topic introduction	page 3
2	Purpose of report	page 3
3	Primary audience and stakeholders	page 3
4	Overview of perspectives	page 4
5	Proponents	page 4
6	Opponents	page 5
7	Relevant attacks	page 6
8	Conclusion	page 7
9	Recommendations	page 7
10	References	page 8

List of illustrations

Figure 1: Example of how commits can be falsified	page 4
Figure 2: Requiring contributors to sign commits	page 7

1. Topic introduction

- a. Open-source software has taken over the tech industry. Today, it is estimated that 96% of code bases incorporate open-source software. While open-source software has many benefits, it also comes with notable cybersecurity risks. Because open-source software relies on contributions from a diverse community of developers, it is vulnerable to threat actors creating malicious commits. Threat actors may attempt to commit malicious code directly into a project, or through a dependency of the project they are targeting in a supply chain attack. Currently, GitHub is the most popular platform for open-source software development, as well as the most targeted by threat actors. When committing to GitHub, attackers are able to falsify their commits to make it look like the code is coming from a reputable source, making it more likely for their malicious code to be introduced into their targeted code base. The solution to this is commit signatures which allow you to verify that a commit originates from the actual owner of an account using public and private keys, but it is not typically required to sign commits. As a software developer who utilizes open-source software constantly, it is clear to me how important it is to take this security risk seriously and how large of a threat it poses to the security of the systems we use every day.

2. Purpose of report

- a. Cybersecurity is becoming an increasingly important aspect of our everyday lives as the amount of important personal information stored online grows. As open-source software quickly becomes widely used, it is important to keep up with emerging threats. Malicious code injection into GitHub repositories is an emerging threat that is becoming increasingly more prevalent while not being addressed properly. This report will seek to address this threat and assess the feasibility of requiring signed commits for repositories to mitigate the risk of commits with falsified credentials. Many perspectives will be explored as the issue of requiring signed commits on GitHub is a complex and contentious issue with strong benefits and disadvantages on both sides.

3. Primary audience and stakeholders

- a. The primary audience for this report is those who are knowledgeable about open-source software security and more specifically those who manage open-source repositories on GitHub, as well as those who contribute to open-source projects.
- b. One of the main stakeholders of this issue is software developers who contribute to open-source projects. Requiring signed commits could potentially slow down their development process and make development less flexible. The other primary

stakeholders are end-users and consumers of software who benefit from increased security.

4. Overview of perspectives

- a. Proponents of mandatory signed commits for repositories believe that they are essential for ensuring the security of open-source software by preventing the injection of malicious code.
- a. Opponents of mandatory signed commits for repositories believe that the added friction in the development workflow and the complexity of implementing new requirements would outweigh the security benefit of signed commits. Another reason for objection is privacy concerns for those who prefer to contribute to open-source projects anonymously, as cryptographic signatures can potentially reveal information about a contributor. They might also feel that commits are unnecessary for some repositories, such as private personal projects, and therefore add extra complexity with no benefit.

5. Proponents

- a. Those who believe signing commits should be required for repositories believe it is essential for ensuring the security of an open-source repository. This is because in open-source software development, maintaining a secure and trustworthy codebase is crucial. Currently, GitHub is the most popular platform for open-source software development, as well as the most targeted by threat actors. One of the most important ways to maintain safe code on GitHub signing commits. In his article, [How \(and why\) to sign Git commits](#), Alessandro Selgala explains what signing a commit is able to verify: “The author is really the person whose name is on the commit” and “The code change you see is really what the author wrote (i.e. it’s not been tampered with)”. When a commit is not signed, these things cannot be verified. Because of this, when committing an unsigned commit to GitHub, attackers are able to falsify their commits to make it look like the code is coming from a reputable account, even linking to the trusted account when clicked on.

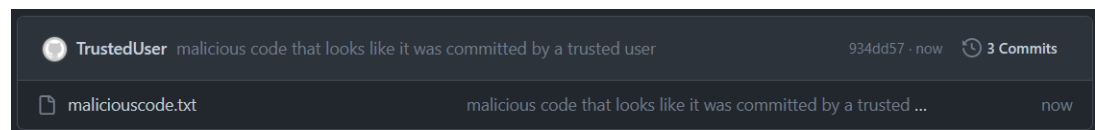


Figure 1: Example of how commits can be falsified to look like they are coming from another account

This is a problem because it can trick reviewers into thinking that the code is coming from someone else, potentially making them blindly accept the code without looking at it or taking less time to review it.

Richard Dubniczky discusses another reason why requiring signed commits for repositories is important in his article Why and How You Should Sign All Your Git Commits. He claims not signing commits "gives users plausible deniability over their work." This means that someone can reasonably claim that they didn't make a commit that they actually did, and it can't be proven false. This can lead to multiple problems. Trusted contributors or employees could decide to commit malicious code for their benefit, and then claim that it wasn't them, avoiding potential workplace or even legal consequences. Contributors could also claim bad code or code containing bugs was not actually contributed by them.

Requiring signed commits isn't only good for security though. In his article, Why You Should Sign Your Commits on GitHub, Harut Abgaryan discussed how signing commits can also create an audit trail. This means in the event of malicious code or even just bugs, "signed commits help maintainers trace back to the exact commit that introduced the change and identify who was responsible".

The solution to all of these problems is requiring signed commits for a repository. It ensures that all of the commits to a repository are really from who they say they are.

6. Opponents

- a. Those who are opponents of repositories requiring commits to be signed may have various different reasons for being so. The biggest reason is because of the potential for added friction in the development workflow. In his article, Should You Sign Git Commits?, Dan Lorenc states, "Unless you're really worried about the impersonation angle, I don't really recommend signing git commits for most people." In this article, he discusses how many people assume signing GitHub commits is mainly important for account protection when in reality it is to avoid impersonation. He discusses how the time to implement may not be worth it for most people because they are unlikely to actually be impersonated. It can be assumed that he would not be in favor of repositories requiring signed commits as he does not believe most people need to sign their commits.

There are also potential time requirements and additional complexity for implementing required signed commits for a repository.

Some people may also be concerned about required signed commits because of privacy concerns and a desire for anonymity. When signing a commit, it verifies that the commit is connected to an account. Some open-source software developers may prefer to be anonymous with their commits and not want the code they write to be linked to their GitHub account. Cryptographic signatures can also potentially reveal information about a contributor that they want to remain secret.

It is important to note that some repositories do not need to require signed commits. For instance, private repositories and repositories that only have one or two contributors don't have a use for signing commits because there is no one to impersonate.

In summary, opponents of repositories requiring signed commits believe that the added friction in the development workflow and the complexity of implementing new requirements would outweigh the security benefit of signed commits.

7. Relevant attacks

- a. Signing GitHub commits is no longer just a precaution but is becoming necessary as open-source attacks become more sophisticated and more common. The recent backdoor found in the XZ Utils GitHub repository ([CVE-2024-3094](#)) is a great example of this. [Microsoft FAQ and guidance for XZ Utils backdoor](#) provides in-depth information about this attack. The backdoor was created by a GitHub user who gained trust first by fixing bugs and then was able to commit malicious code without being noticed. This is an example of how trusted users can submit malicious code because their code may not be reviewed as thoroughly.
- b. In his article, [Should You Sign Git Commits?](#), Dan Lorenc brings up a situation where a large number of GitHub users protested the takedown of Youtube-dl by forging commits attributed to Nat Friedman, the CEO of GitHub. This demonstrates how easy it is to create false commits, although these commits were not meant to be believed.
- c. In a very recent attack discussed in Jossed Harush Kadouri's article [Large Scale Campaign Created Fake GitHub Projects Clones with Fake Commit Added Malware](#), millions of GitHub repositories were forked to create malicious copies in an attempt to trick people into downloading them. After automatically forking the repositories, the attackers would fake their commits to look like the original committers' identity. This made their repositories look more legitimate, tricking people into downloading them instead of the legitimate version they were searching for.

- d. In his article, [Stolen GitHub Credentials Used to Push Fake Dependabot](#), Ionut Arghire discusses an attack technique being observed where attackers used stolen access tokens to gain access to repositories, then created fake commits with malicious code that appeared to come from Dependabot, GitHub's free automated dependency management tool.

8. Conclusion

- a. It is evident that the prevalence of unsigned commits poses a significant threat to the integrity of Github repositories. Upon weighing the perspectives of proponents and opponents of mandatory signed commits for repositories, it becomes clear that while there are valid concerns regarding the added complexity and potential privacy implications, the security benefits outweigh these drawbacks. By requiring signed commits, repository owners and maintainers can significantly mitigate the risk of malicious code injection.

9. Recommendations

- a. Based on the analysis presented in this report, it is recommended that owners and maintainers of GitHub repositories implement mandatory signed commits. To facilitate this transition, organizations should provide comprehensive guidance and support to developers, including training on cryptographic key management and best practices for commit signing.
- b. Requiring commits for a repository can be done in a couple of steps:
 - Navigate to the main page of your repository
 - Click **Settings**
 - Under **General**, Select **Require contributors to sign off on web-based commits**

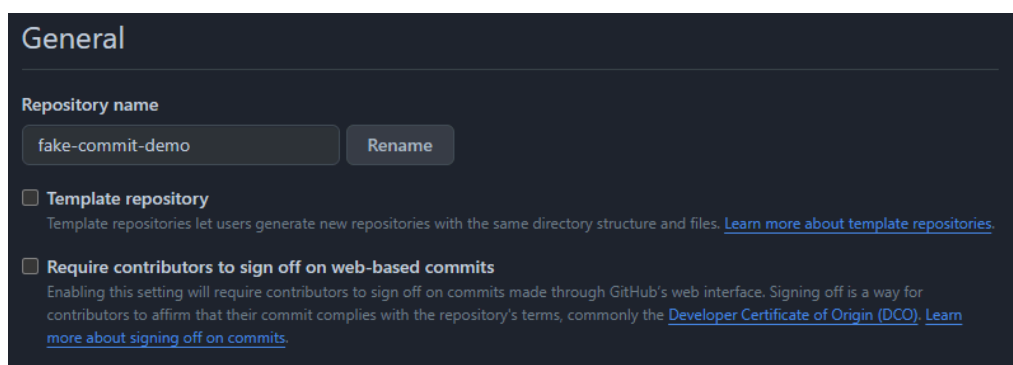


Figure 2: Requiring contributors to sign commits

For additional information about how to sign commits and require signed commits for a repository, see [Signing GitHub Commits: How and Why](#)

10. References

- a. Segala, A. (2020, May 17). *How (and why) to sign Git commits*. With Blue Ink. <https://withblue.ink/2020/05/17/how-and-why-to-sign-git-commits.html>
- b. Dubniczky, R. (2022, July 16). *Why and how you should sign all your git commits*. Medium. <https://betterprogramming.pub/why-and-how-you-should-sign-all-your-git-commits-94435516edae?gi=2fb350be50af>
- c. Abgaryan, H. (2024, April 15). *Why you should sign your commits on github*. Medium. <https://medium.com/@harutyunabgaryann/why-you-should-sign-your-commits-on-github-2ebd2d4102ee>
- d. Lorenc, D. (2021, July 4). *Should you sign git commits?*. Medium. <https://dlorenc.medium.com/should-you-sign-git-commits-f068b07e1b1f>
- e. NVD. (n.d.-a). <https://nvd.nist.gov/vuln/detail/CVE-2024-3094>
- f. *Microsoft FAQ and guidance for XZ Utils Backdoor*. TECHCOMMUNITY.MICROSOFT.COM. (2024, April 7). <https://techcommunity.microsoft.com/t5/microsoft-defender-vulnerability/microsoft-faq-and-guidance-for-xz-utils-backdoor/ba-p/4101961>
- g. Kadouri, J. H. (2022, August 3). *Large scale campaign created fake github projects clones with fake commit added malware*. Medium. <https://medium.com/checkmarx-security/large-scale-campaign-created-fake-github-projects-clones-with-fake-commit-added-malware-d6529db5e953>
- h. Arghire, B. (2023, September 27). *Stolen github credentials used to push fake Dependabot commits*. SecurityWeek. <https://www.securityweek.com/stolen-github-credentials-used-to-push-fake-dependabot-commits/>